

6. Web y APIs

De discovery web a bugs de autorizacion, SSRF, JWT y uploads.

Fingerprinting y discovery

```
curl -i $URL/  
whatweb -a 3 $URL  
ffuf -u "$URL/FUZZ" -w /usr/share/wordlists/dirb/common.txt -e .php,.txt,.html -fc 404  
ffuf -u "$URL/" -H "Host: FUZZ.target.local" -w subdomains.txt -fs 0  
katana -u $URL -d 3  
arjun -u "$URL/page.php"
```

Triage de bugs

Bug	Senales y prueba inicial
LFI	Parametros file/page/lang/template. Probar ../../../../etc/passwd y php://filter.
SSTI	Payloads {{7*7}}, \${7*7}, <%= 7*7 %>; confirmar motor antes de explotar.
IDOR/BOLA	Cambiar IDs entre usuarios. Si ves datos ajenos, hay autorizacion rota.
JWT	Revisar alg, kid, role, user_id, exp. Probar solo si el reto apunta a firma debil.
GraphQL	Introspection, tipos, queries/mutations con id/userId/admin/debug.
SSRF	Parametros url/webhook/avatar/import. Confirmar contra tu listener antes de localhost.
XXE	Entradas XML/SVG/SOAP/SAML/DOCX; probar entidad file:///etc/passwd en lab.
Upload	Extension, Content-Type, magic bytes, doble extension, ruta de ejecucion.
Command injection	host/ip/domain/filename. Confirmar con id/whoami/hostname o delay controlado.